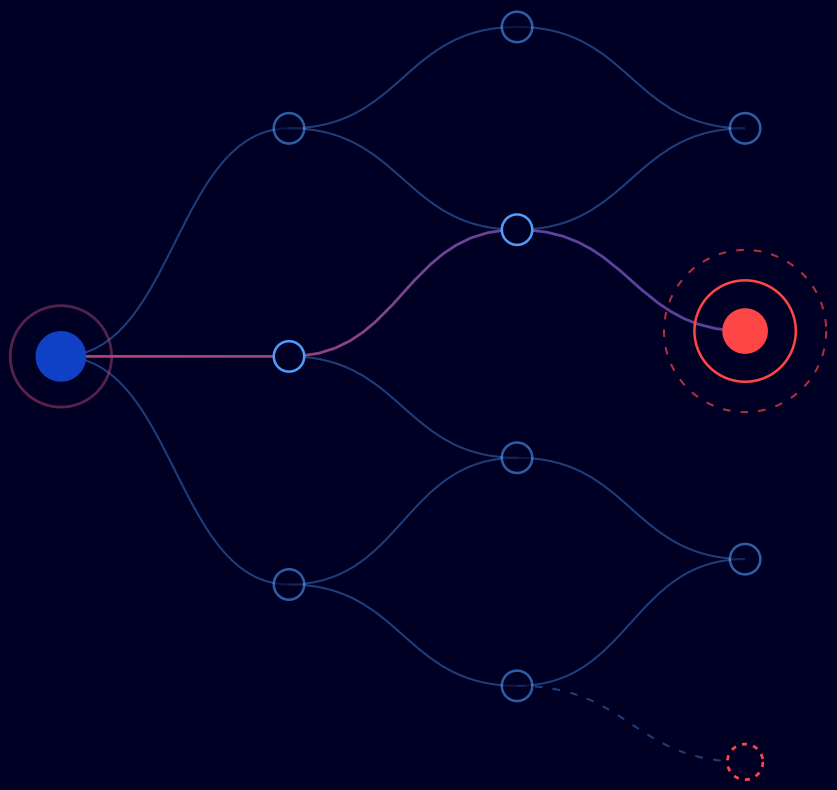
AccuKnox

Fix the flaws attackers can really reach

Seven do's and don'ts for application security posture management, from the first commit to the closed ticket.



The problem

The backlog grows faster than teams can fix it

Each year brings more published CVEs, more leaked keys and more findings from more scanners. Fix times are getting longer, so the gap between what you found and what you closed keeps growing.

48,244

CVE records published in 2025, up from 40,077 in 2024.

CVE Program metrics, cve.org

28.6M

New secrets found in public GitHub commits in 2025, up 34% in one year.

GitGuardian, State of Secrets Sprawl 2026, gitguardian.com

43 days

Median time to fully fix a CISA KEV vulnerability in 2025, up from 32 days. Only 26% were fully fixed.

Verizon 2026 DBIR, verizon.com

Root causes

Four habits keep the backlog growing



Each scanner reports alone

SAST, DAST, SCA, IaC, secret and container tools each keep their own console. The same flaw lands in several lists, and nobody owns the total.



Severity stands in for risk

Datadog found that only 18% of critical dependency vulnerabilities stay critical after runtime context, exploit availability and EPSS adjust the score.



Scans run after the merge

Vulnerability exploitation started 31% of breaches in the 2026 DBIR, up from 20%. A flaw first found in production has already been exposed.



Leaked keys stay valid

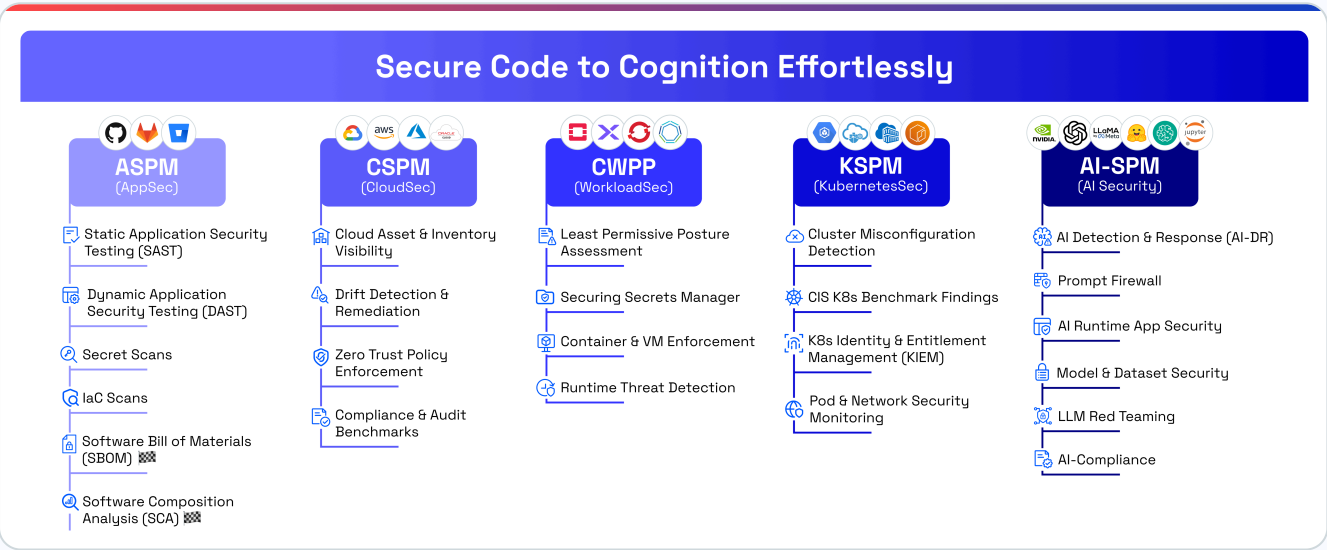
GitGuardian reports that 64% of the secrets leaked in 2022 are still active. Deleting the commit does not revoke the key.

Sources: Datadog, State of DevSecOps 2026, datadoghq.com. Verizon 2026 DBIR, verizon.com. GitGuardian, State of Secrets Sprawl 2026, gitguardian.com.

Start here

Seven practices, one pipeline

AccuKnox ASPM runs SAST, DAST, SCA, IaC, secret and container scans, and keeps the findings in the same CNAPP as your cloud and runtime data.



ASPM inside the AccuKnox CNAPP. help.accuknox.com/how-to/aspm-overview

01 **One findings queue** 05
Every scanner, one place

02 **Exploitability first** 06
EPSS and runtime evidence

03 **Scan every repo** 07
Where developers commit

04 **Stop leaked secrets** 08
Before the merge

05 **Gate the pipeline** 09
Observe first, then enforce

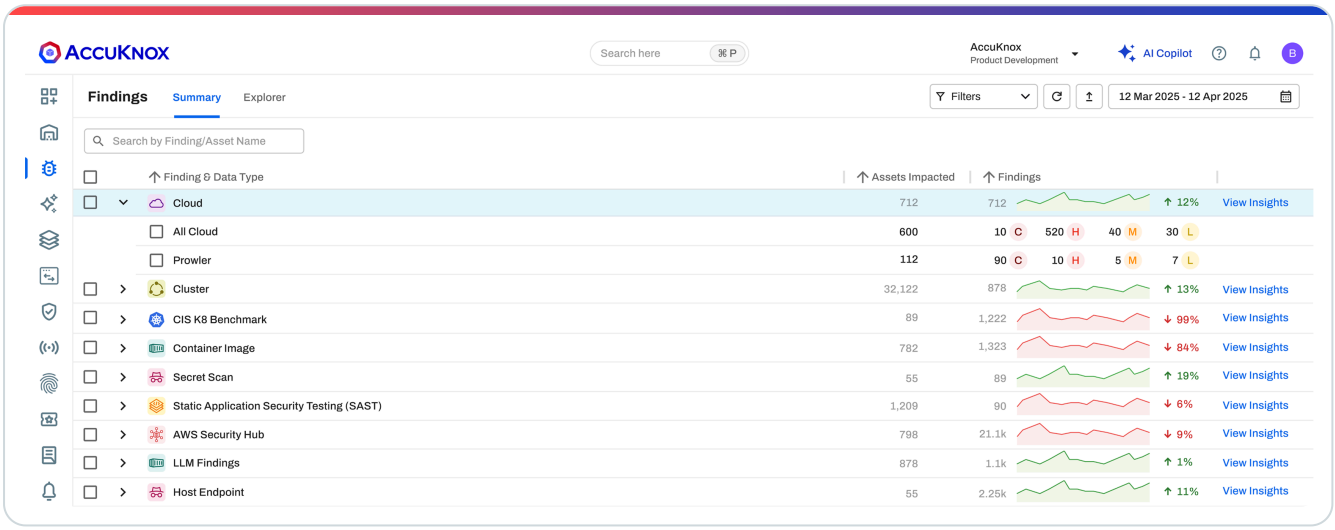
06 **SBOM per build** 10
Know what changed

07 **Owned tickets** 11
Rules route and close work

Practice 01

Send every scanner to one queue

Findings from SAST, DAST, SCA, IaC, secret and container scans land in Issues, Findings, next to cloud and cluster data.



Findings summary by data type. help.accuknox.com/use-cases/aspm

DO

- Upload every scan result to AccuKnox and filter by Data Type, such as SAST or IaC Scan.
- Give each repo and image a label per team or environment.
- Keep SonarQube if you run it. AccuKnox ingests its results.
- Schedule an ASPM report so owners get one PDF by email.

DON'T

- Don't triage in six consoles with six severity scales.
- Don't count the same flaw once per tool in your metrics.
- Don't send scan results to a tool nobody opens.

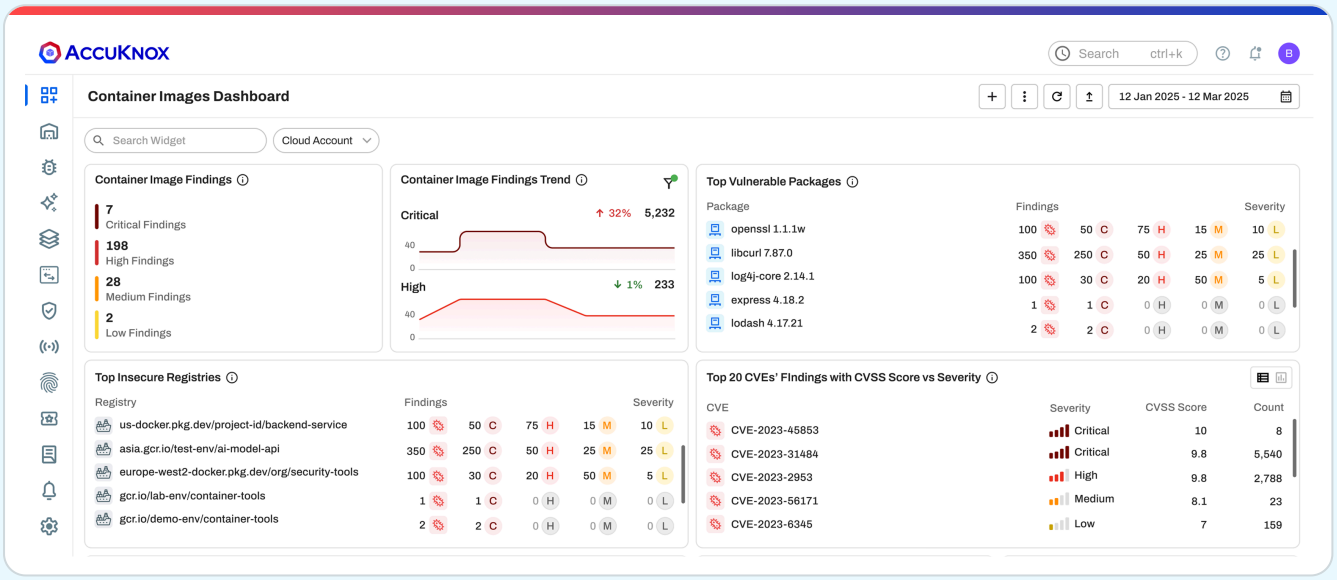
HOW ACCUKNOX CLOSES THE GAP

The ASPM Scanner CLI runs IaC, SAST, SonarQube SAST, secret, container and DAST scans with one command and uploads the results. Install the ASPM Scanner CLI

Practice 02

Fix what attackers can exploit first

CVSS rates how bad a flaw is. EPSS estimates the chance of exploitation in the next 30 days.



Container Images dashboard. help.accuknox.com/use-cases/epss-scoring

DO

- Sort container CVEs by EPSS score and percentile, shown beside CVSS.
- Fix first where high CVSS, high EPSS and a CWE Top 25 or KEV weakness meet.
- Use the Runtime Verified flag to find packages that run in production.
- Recheck priorities often, because EPSS scores update daily.

DON'T

- Don't rank the backlog by CVSS alone.
- Don't treat EPSS as the full picture. It ignores your environment and impact.
- Don't park a medium CVE that has a public exploit.

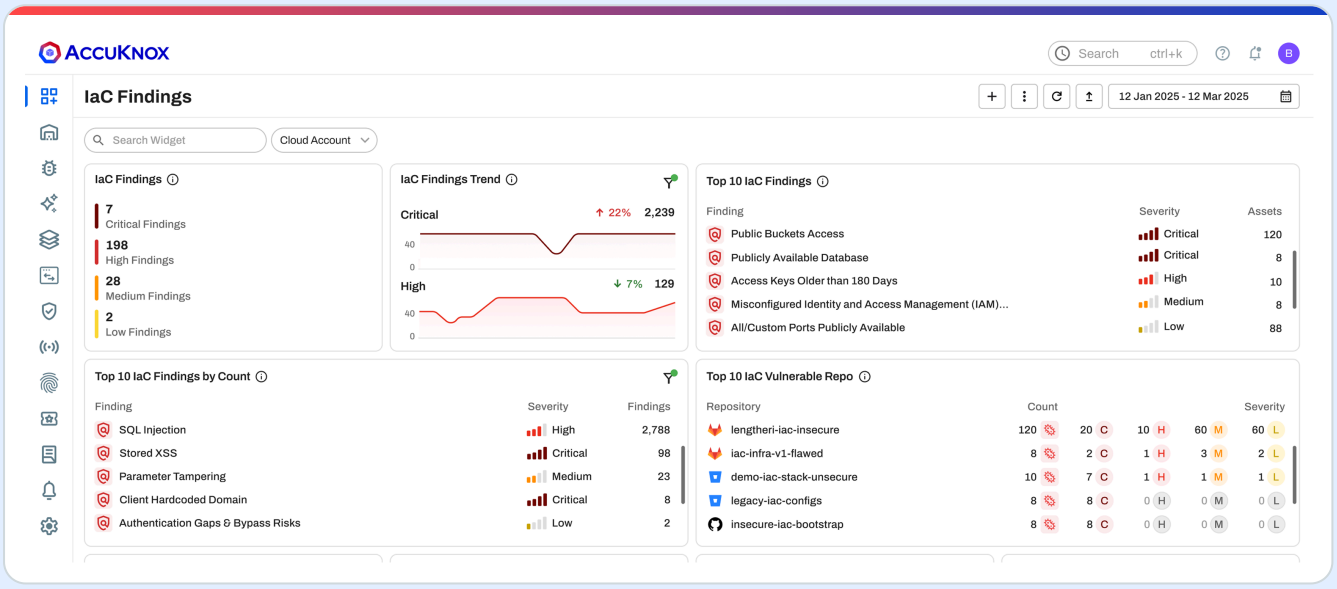
HOW ACCUKNOX CLOSES THE GAP

The AccuKnox Vulnerability Database adds EPSS to container image findings. Runtime Verified uses KubeArmor eBPF telemetry with CISA KEV and EPSS enrichment. Read the Vulnerability DB page

Practice 03

Scan code where developers commit it

A public S3 bucket in Terraform costs one review comment. The same bucket in production costs an incident.



IaC Findings dashboard. help.accuknox.com/how-to/code-source-onboarding

DO

- Connect GitHub, GitLab or Bitbucket with the App Based integration and pick SCA, Secrets, SAST, SBOM and IaC.
- Tick Auto connect new repos so new code gets scanned.
- Add scan steps to GitHub Actions, GitLab, Jenkins or Azure DevOps.
- Let developers run the CLI locally with upload skipped.

DON'T

- Don't wait for a yearly pentest to find a public bucket in Terraform.
- Don't scan only the default branch when releases ship from others.
- Don't expect the app flow on Bitbucket Data Center. Use the CI/CD integration.

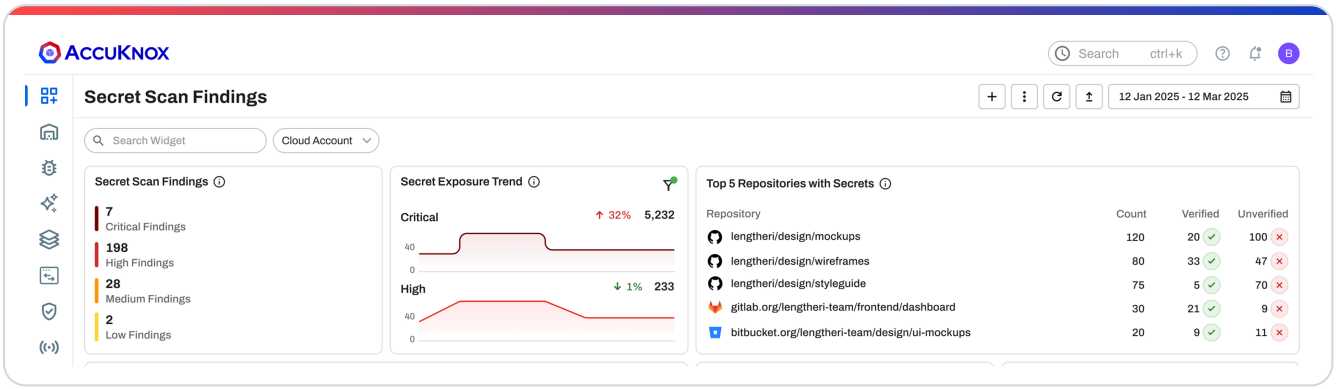
HOW ACCUKNOX CLOSES THE GAP

The AccuKnox app asks for read only access and needs no pipeline change. CI/CD and CLI integrations run the same scanners. Connect your source code

Practice 04

Stop a secret before it reaches the repo

A key in Git history stays usable until someone revokes it, even after the file changes.



Secret Scan Findings dashboard. help.accuknox.com/use-cases/secret-scan-cicd-aws

DO

- Run the secret scan on every push and pull request.
- Scan the full Git history, not only the latest commit.
- Revoke and rotate a leaked key first, then clean history with BFG Repo Cleaner.
- Move secrets to Vault, AWS Secrets Manager or Azure Key Vault.

DON'T

- Don't rely on grep or code review to catch keys.
- Don't call a leak fixed when you only deleted the file.
- Don't forget images and ConfigMaps. Secrets hide there too.

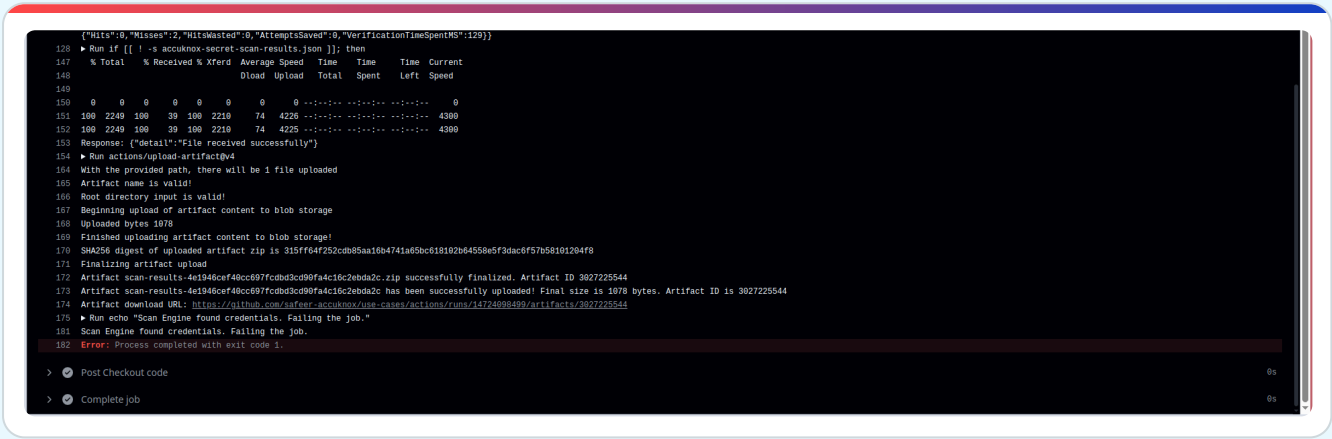
HOW ACCUKNOX CLOSES THE GAP

Each finding shows the secret type, file path, commit SHA and author. AccuKnox receives the finding details, never the secret value. Add secret scanning to CI/CD

Practice 05

Gate the pipeline, but observe first

A gate that breaks every build on day one gets switched off by day three.



A secret scan failing the job in GitHub Actions. help.accuknox.com/use-cases/secret-scan-cicd-aws

DO

- Start with soft_fail set to true, so findings upload and the build stays green.
- Set a date to switch to hard fail on critical and high findings.
- Fail the container build on critical CVEs before the image is pushed.
- Run a DAST baseline scan in CI and a full scan in staging.

DON'T

- Don't leave soft fail on forever. Then the gate is only a report.
- Don't run a full DAST scan on every pull request.
- Don't let images from unknown registries reach the cluster.

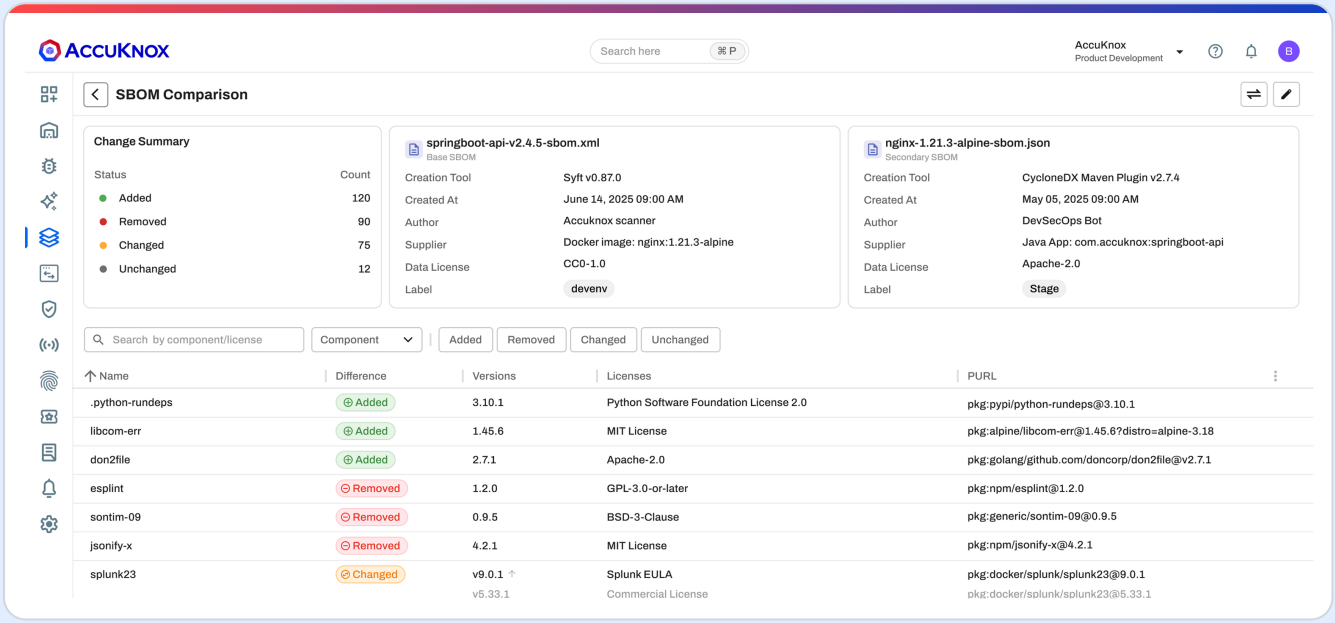
HOW ACCUKNOX CLOSES THE GAP

AccuKnox scan steps take a soft or hard fail setting. KnoxGuard blocks deployments that pull images from untrusted registries. Set up KnoxGuard

Practice 06

Keep an SBOM for every build

When the next Log4Shell lands, an SBOM shows which releases ship the package.



SBOM Comparison. help.accuknox.com/getting-started/xbom-setup

DO

- Generate a CycloneDX or SPDX SBOM in CI on every build.
- Upload SBOMs from Syft or Trivy if you already make them.
- Compare two SBOMs before release to see added and changed packages.
- Review license findings. Strong copyleft rates High, banned licenses Critical.

DON'T

- Don't build an SBOM once, only for the audit.
- Don't skip the packages that the base image brings in.
- Don't ignore a new dependency nobody asked for.

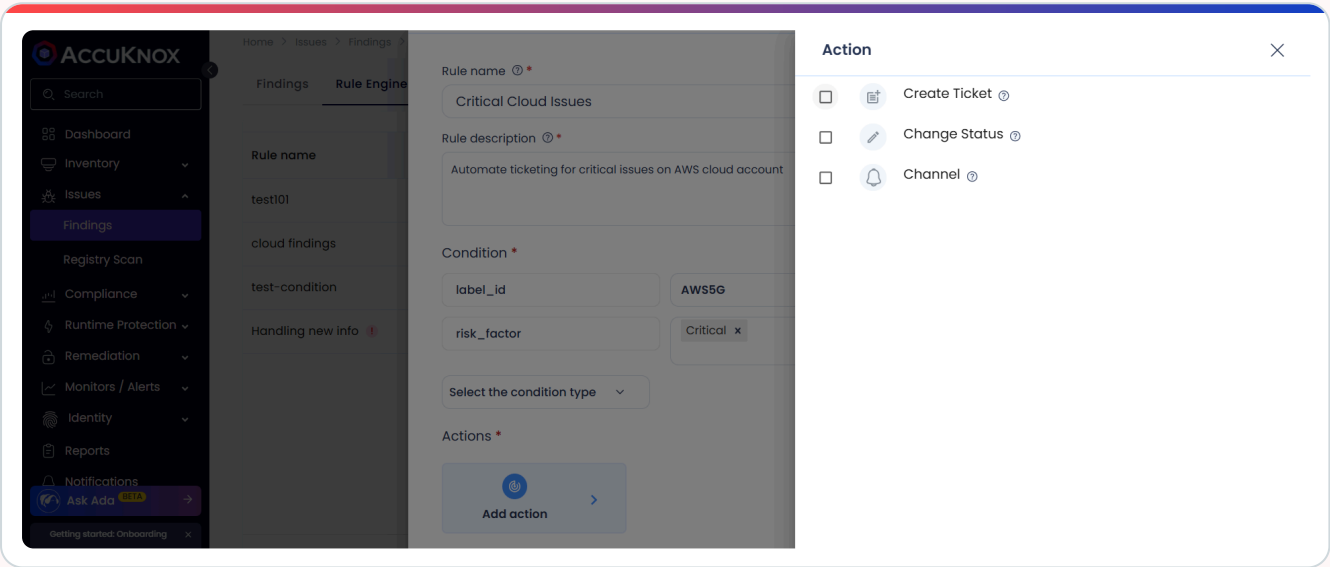
HOW ACCUKNOX CLOSES THE GAP

AccuKnox scans each SBOM for vulnerabilities, license issues and dependency risk, and tracks changes between versions. Read the SBOM FAQ

Practice 07

Turn findings into owned tickets

A finding with no ticket and no owner waits in the backlog until an attacker finds it.



Rule Engine with a Create Ticket action. help.accuknox.com/use-cases/rules-engine-ticket-creation

DO

- Connect Jira or ServiceNow, then create a Rule Engine rule with a Create Ticket action.
- Set the Parent field to Asset Name so each asset gets one parent ticket.
- Let a rescan move a finding to Fixed and close its ticket.
- Mark a false positive as an exception with a written reason.

DON'T

- Don't open one ticket per finding by hand.
- Don't close a ticket before a scan confirms the fix.
- Don't let a rule expire unnoticed. An expired rule stops creating tickets.

HOW ACCUKNOX CLOSES THE GAP

A finding moves from Active to Waiting for Verification to Fixed once two scans agree, and the linked ticket closes with it. Create your first rule

Gap check

Find your gap, then take the first step

Read each row. Where the statement is true for your team, start the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Each scanner has its own console and nobody sees the total	ASPM findings and reports	Upload results with the ASPM Scanner CLI and schedule an ASPM report
The team fixes CVEs in CVSS order	EPSS and Runtime Verified	Sort container findings by EPSS and turn on runtime verification
Some repos get no SAST, SCA or IaC scan	App Based code source scanning	Install the AccuKnox app and tick Auto connect new repos
Keys can reach the repo without a check	Secret scanning in CI/CD	Add the secret scan step with fail set to true
Builds pass whatever the scans find	Soft and hard fail gates, KnoxGuard	Start in soft fail, then set a hard fail date
Nobody can say which releases ship a given package	SBOM generation and comparison	Generate an SBOM in CI for each build
Findings wait with no owner or ticket	Rule Engine smart tickets	Connect Jira and create a rule with a Parent field

AccuKnox

See your whole AppSec backlog in one place

Bring your gap check to a demo. We connect a repo, run the scans and rank the findings with you.

Book a demo | **Open the ASPM docs**

2026

KuppingerCole CNAPP Leadership Compass features AccuKnox, citing DevSecOps and unified risk correlation.

Gartner

Emerging Tech techscape profiles AccuKnox among startups joining cloud and application security.

6

Scan types in one ASPM Scanner CLI, from IaC and SAST to secrets, containers and DAST.

Sources: accuknox.com/analyst-recognition and help.accuknox.com/use-cases/aspm-scanner-cli

accuknox.com · © 2026 AccuKnox, Inc.